



# **Auditoria Web**

## **OWASP**

Iván Martín Carretero

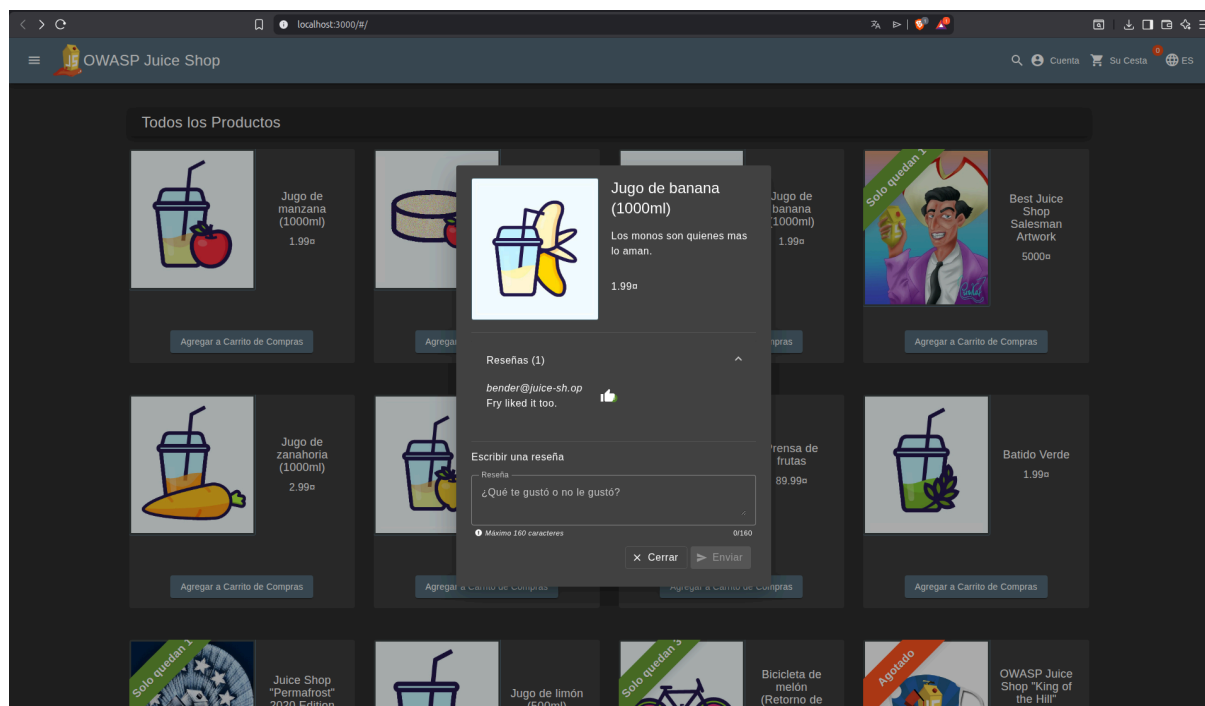


# Índice

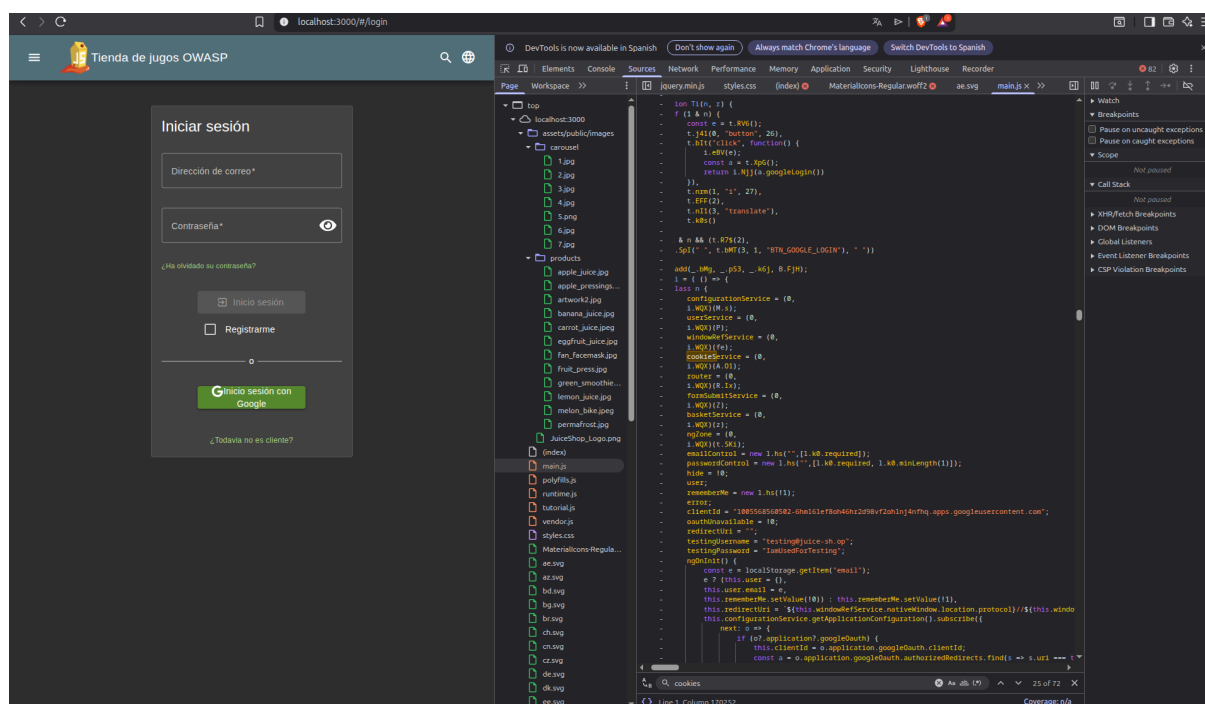
|                                           |          |
|-------------------------------------------|----------|
| <b>Auditoria Web OWASP</b>                | <b>1</b> |
| <b>1. Investigación</b>                   | <b>3</b> |
| <b>2. Informe de Vulnerabilidades</b>     | <b>5</b> |
| <b>3. Explotación de Vulnerabilidades</b> | <b>7</b> |

# Auditoria Web OWASP

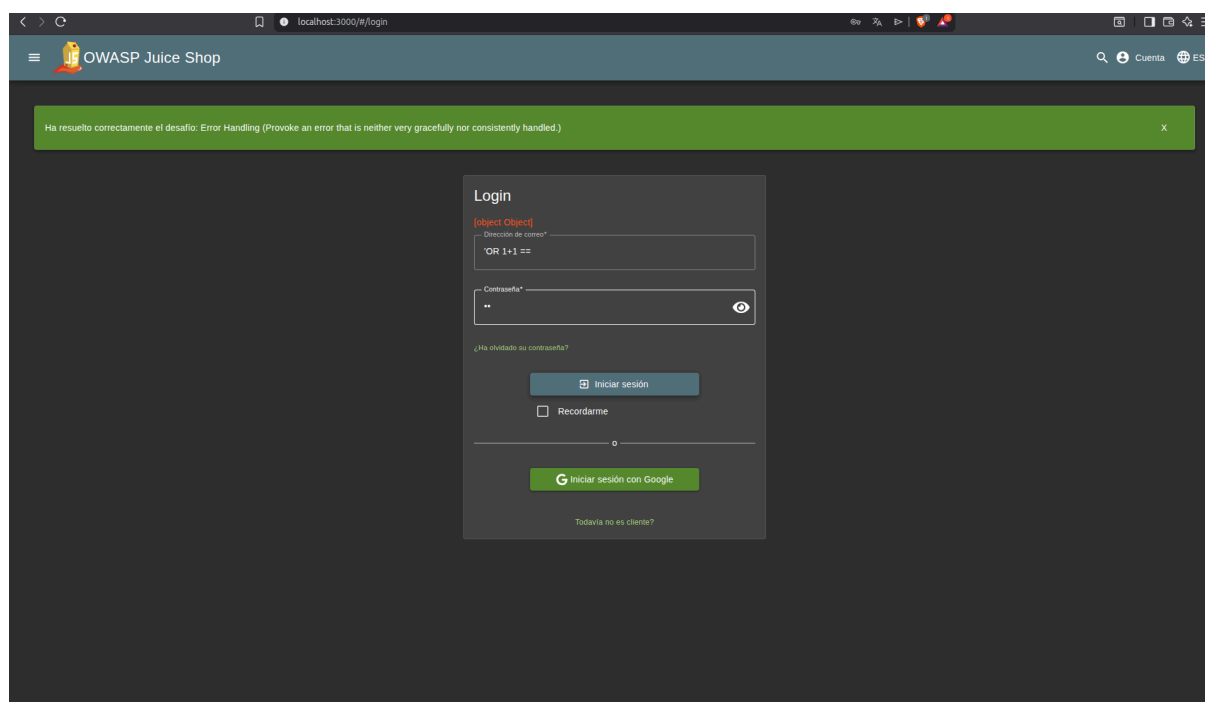
## 1. Investigación



Cuando accedemos a la página lo primero que mire fue los productos que están vendiendo, al acceder a uno de los productos he visto que tienen reseñas con usuarios autenticados lo que da indicio de que pueden estar guardando las cookies de dichos usuarios y se podría explotar la vulnerabilidad de robo de sesión con la herramienta de Burp Suites por ejemplo.



Luego como la página tiene para iniciar sesión mire con la herramienta de desarrollador con el F12, hay muchos archivos pero entre ellos decidir mirar el código del archivo main.js. Mirando el código decidí buscar palabras claves como cookies, token, email... y encontré un email y la password de un usuario en texto plano que lo pude usar para loguearme como esa persona



Volviendo al panel de login pensé que se podríamos hacer un ataque de SQL Injection para ver qué podía pasar y por sorpresa ese panel de login lo pude saltar y me inicio sesion como usuario administrador

## 2. Informe de Vulnerabilidades

En esta página web he encontrado vulnerabilidades como SQL Injection, robo de cookies de inicio de sesión, ataques de Cross Sites Scripting e incluso el archivo [main.js](#) de la página web con emails y password visibles en texto plano

SQL Injection = Este ataque ocurre cuando la página web o la aplicación está haciendo consultas de SQL para validar usuarios como en este caso. Con este ataque consigues engañar a la base de datos para que muestre



información confidencial o incluso puedas iniciar sesión como administrador como en este caso.

Cuando se hace una consulta a la base de datos SQL es una cosa así :  
`SELECT * FROM usuarios WHERE nombre : 'USUARIO' AND clave = 'PASSWORD';`

Entonces para hacer el ataque, en el panel de login introduces `PASSWORD: ' OR '1'='1` y lo que está pasando en la consulta es `SELECT * FROM usuarios WHERE nombre = 'admin' AND clave = " OR '1'='1';` y lo que está pasando es que al introducir `' OR '1'='1` le estamos diciendo que esa condición siempre es verdadera por lo que se podría iniciar sesión sin saber la contraseña

Robo de cookies de inicio de sesión : Es un ataque en el que se obtiene la cookie de sesión de un usuario para suplantar su identidad. Esto se podría hacer mediante un ataque de Cross-Site Scripting que funciona si la página web puede ejecutar código JavaScript con lo cual podrías introducir código para intentar acceder al archivo en el que se guardan las cookies

Esto también se podría hacer usando el software Burp Suite donde podemos ver todo el tráfico de la página web y podemos llegar a ver las cookies de inicio de sesión

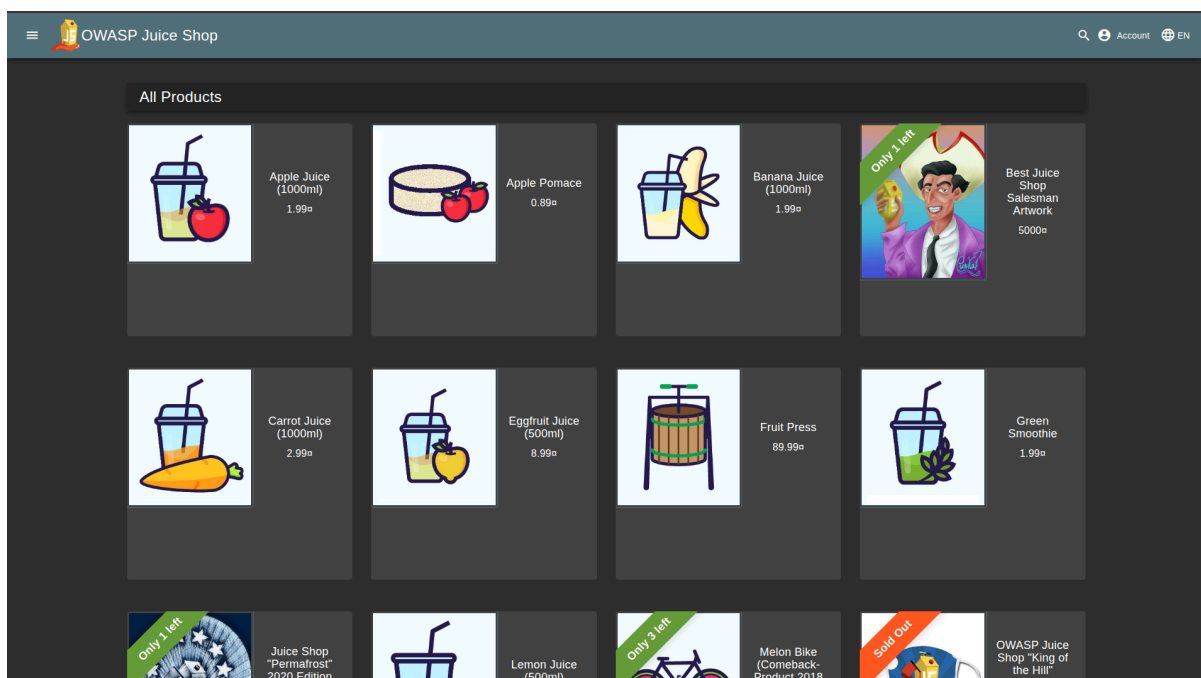
Otra cosa que he encontrado en esta página web es que en el archivo [main.js](#) puedes encontrar usuarios y contraseñas en texto plano. Aunque esto no sea un ataque como tal si son malas prácticas por parte del desarrollador ya que ese archivo está visible con tan solo darle a la tecla

F12 para entrar a las herramientas de desarrollador del navegador, lo cual todo tipo de personas pueden estar viendo usuarios y contraseñas en texto plano

## 3. Explotación de Vulnerabilidades

### Explotación SQL Injection

Para explotar esta vulnerabilidad tenemos que buscar en la página web formularios o paneles de login. En este caso, tras investigar un poco encontré que hay un panel de login. Este panel lo podemos encontrar en la parte superior derecha donde pone Account



Cuando le damos al apartado de Account nos saldrá el siguiente panel de login



## Login



[Forgot your password?](#)

 Log in

☐ Remember me

or

 Log in with Google

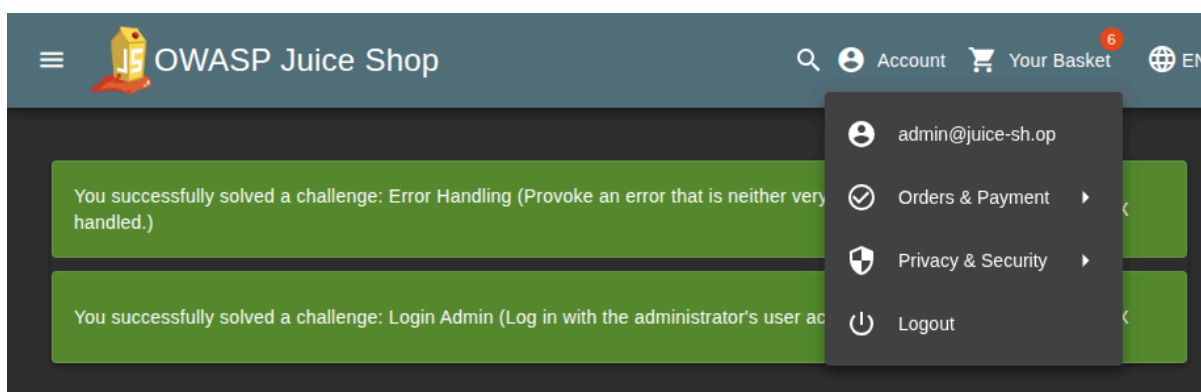
[Not yet a customer?](#)





The screenshot shows a login form with a dark background. At the top, the word "Login" is displayed in white. Below it, there are two input fields. The first field is labeled "Email\*" and contains the text "' OR 1+1 --". The second field is labeled "Password\*" and contains three dots, with a toggle icon (an eye) to its right. Below the password field, there is a link that says "Forgot your password?". Underneath this, there is a blue button with a white arrow icon and the text "Log in". Below the button is a checkbox labeled "Remember me". A horizontal line with the word "or" in the center separates this section from the next. Below the line is a green button with a white "G" icon and the text "Log in with Google". At the bottom of the form, there is a link that says "Not yet a customer?".

Aquí en email pondremos ' OR 1 + 1 – y en la contraseña pondremos lo que queramos, en mi caso puse 12. Luego le daremos a Log in para acceder como administrador



Esto pasa porque el operador lógico OR en SQL consiste en evaluar las condiciones y si una u otra es verdadera, devolverá el valor TRUE. Usamos  $1 + 1$  porque SQL lo interpreta como una expresión válida y cualquier número que sea distinto de 0 lo evalúa como TRUE. Y por último ponemos doble guión, – ya que esto en SQL es un comentario, lo que hace que toda la consulta que venga después de lo añadido se ignore y así impedir que pueda invalidar el ataque

## Mitigación y Evaluación Según Criticidad

Una solución que podemos encontrar es usar consultas parametrizadas ya que de esta manera el servidor enviará la consulta con marcadores de posición en vez de hacer la consulta concatenando el texto del usuario. De esta manera la base de datos trataría la entrada del usuario como datos y no como código ejecutable

Otra manera óptima sería validar las entradas del usuario, es decir que solo se aceptan los tipos de datos esperados a introducir, por ejemplo, si se esperan datos de números que solo se aceptan números, si se esperan datos de correos electrónicos pues que solo se aceptan correos electrónicos



Este ataque se valora con una criticidad de Nivel alto o Alta severidad ya que como hemos podido ver, es posible entrar a dicha página web como usuario administrador sin necesidad de saber su email o su password

## Explotación XSS

Para explotar este ataque XSS y poder robar las cookies de inicio de sesión tendremos que ir a la pagina principal y añadir un producto al carrito para comprarlo



OWASP Juice Shop

Account Your Basket

You successfully solved a challenge: Error Handling (Provoke an error that is neither very gracefully nor consistently handled.)

You successfully solved a challenge: Login Admin (Log in with the administrator's user account.)

**Your Basket** (admin@juice-sh.op)

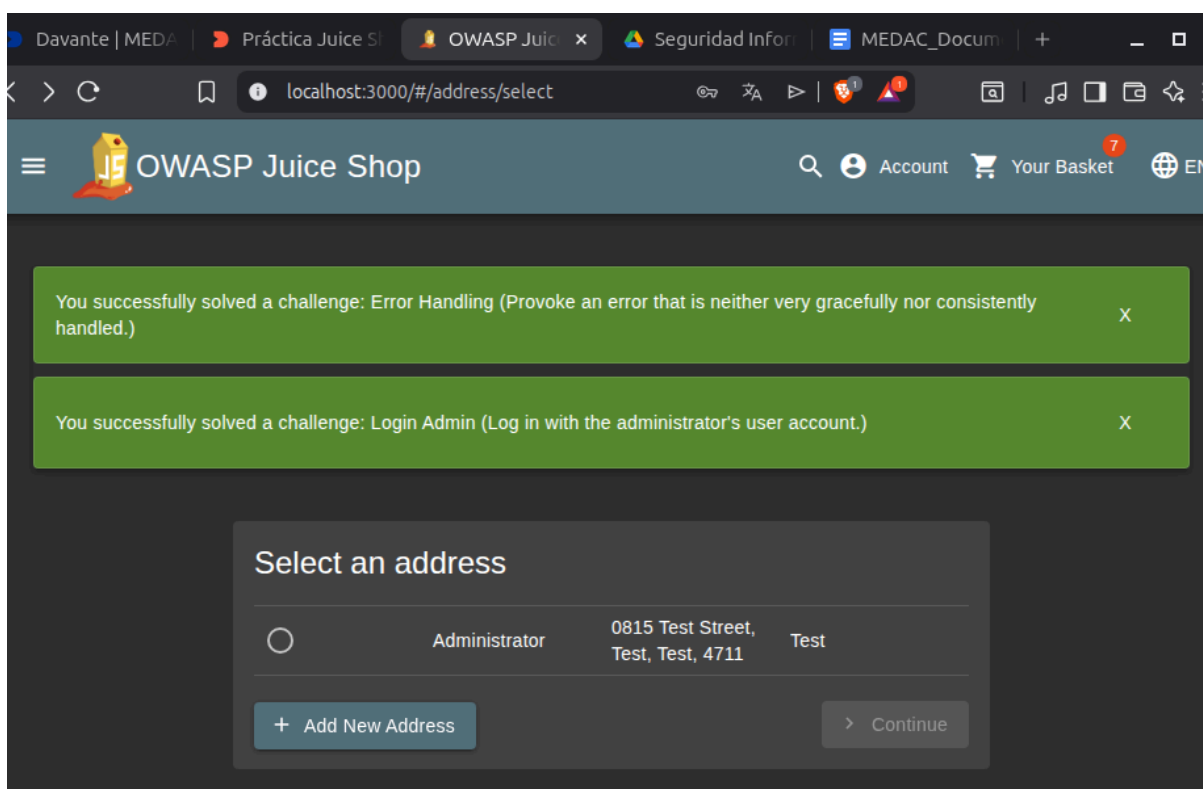
|  |                        |       |       |  |
|--|------------------------|-------|-------|--|
|  | Apple Juice (1000ml)   | - 3 + | 1.99€ |  |
|  | Orange Juice (1000ml)  | - 3 + | 2.99€ |  |
|  | Eggfruit Juice (500ml) | - 1 + | 8.99€ |  |

Total Price: 23.93€

Checkout

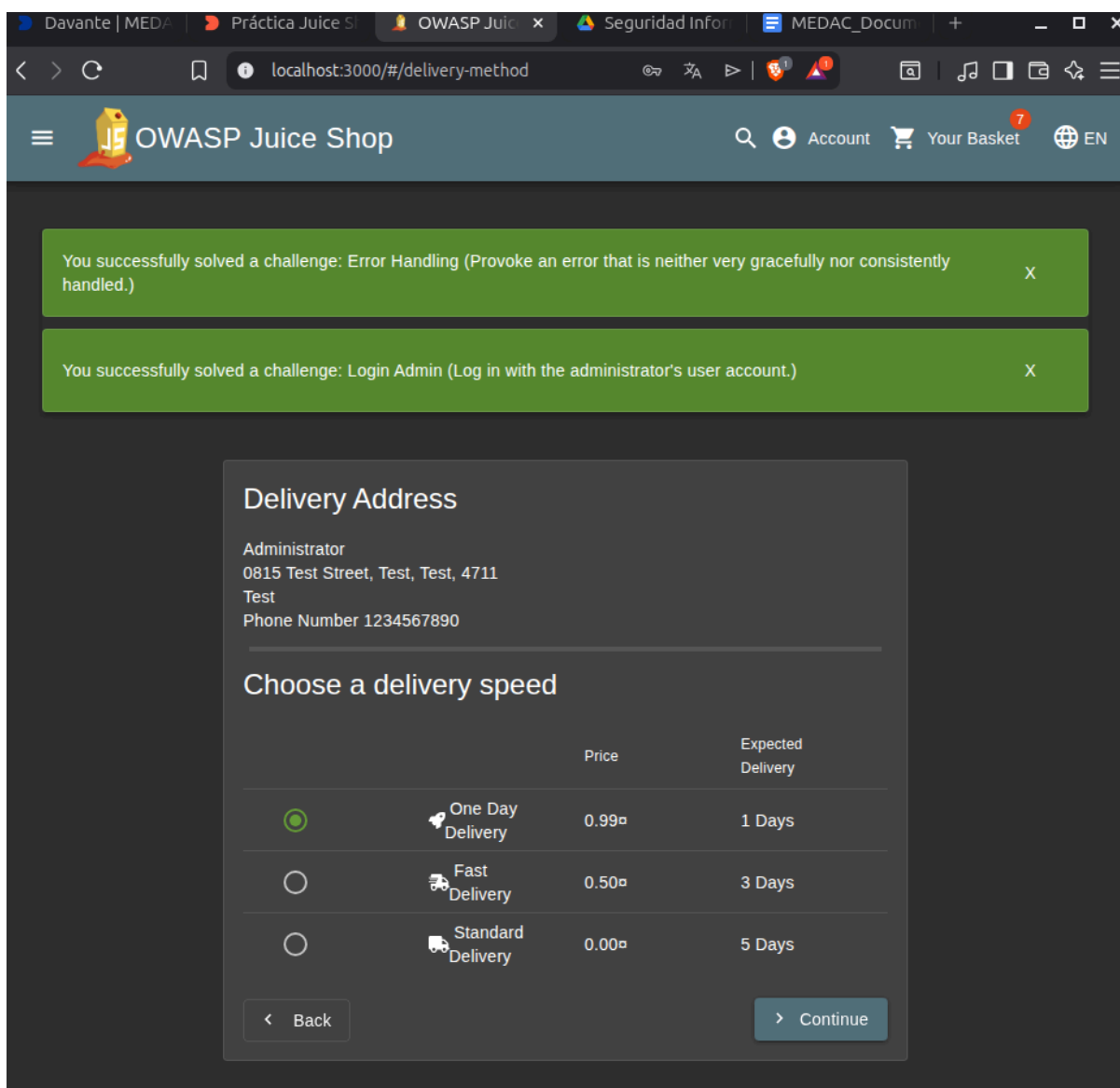
You will gain 1 Bonus Points from this order!

Cuando lo hayamos añadido al carrito le daremos a la parte superior derecha donde pone Your Basket, ahí encontraremos los productos que hemos añadido y le daremos abajo a Checkout

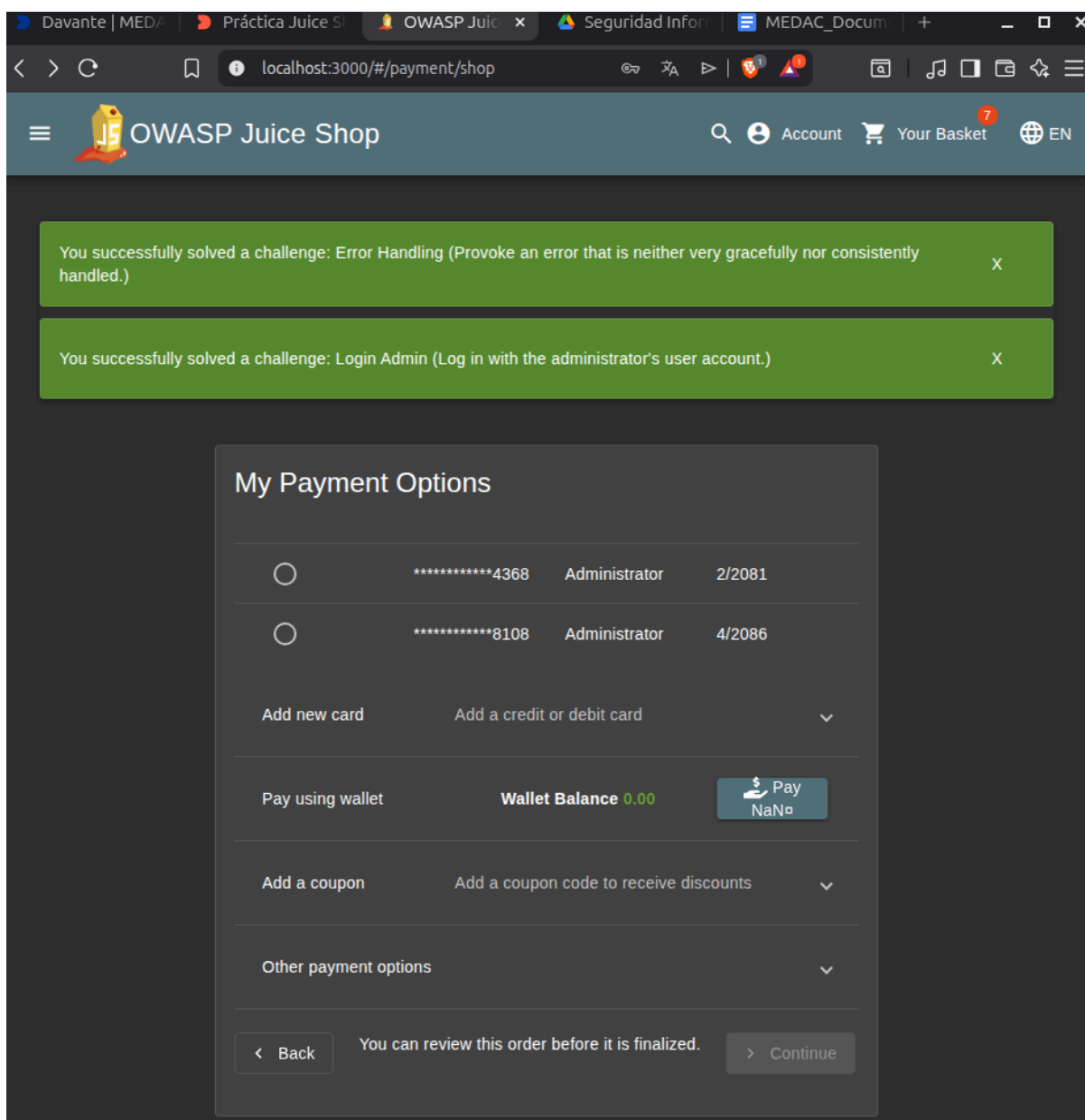


Ahora tendremos que seleccionar una dirección de envío, en mi caso al estar registrado con la cuenta de administrador me sale directamente la dirección de esta persona, si no tendrás que introducir una dirección dándole a Add New Address

Cuando tengamos la dirección de envío añadida, la seleccionamos y le damos a Continue



Seleccionaremos un metodo de envio, da igual el que sea y le damos a Continue



Seleccionaremos una tarjeta para poder pagar, en este caso tenemos las tarjeta de la persona administradora, pero en caso de que no las tengas añade una dándole a Add new card

Cuando tengamos la tarjeta añadida para poder realizar el pago le damos a Continue



The screenshot displays the OWASP Juice Shop interface. At the top, there are two green success messages: "You successfully solved a challenge: Error Handling (Provoke an error that is neither very gracefully nor consistently handled.)" and "You successfully solved a challenge: Login Admin (Log in with the administrator's user account.)". Below these, the page is divided into three main sections: Delivery Address, Payment Method, and Order Summary. The Delivery Address section shows the Administrator's details. The Payment Method section shows a card ending in 4368. The Order Summary section lists the items in the basket: 3 Apple Juice (1000ml) for 1.99 and 3 Orange Juice (1000ml) for 2.99, with a total price of 24.92. A button labeled "Place your order and pay" is visible, along with a note that the user will gain 1 Bonus Points from this order.

| Section            | Item                  | Quantity | Price        |
|--------------------|-----------------------|----------|--------------|
| Your Basket        | Apple Juice (1000ml)  | 3        | 1.99         |
|                    | Orange Juice (1000ml) | 3        | 2.99         |
| Order Summary      | Items                 |          | 23.93        |
|                    | Delivery              |          | 0.99         |
|                    | Promotion             |          | 0.00         |
| <b>Total Price</b> |                       |          | <b>24.92</b> |

Le daremos a al opción de Place your order and pay para realizar el pago de los productos y continuar con el ataque





## Thank you for your purchase!

Your order has been placed and is being processed. You can check for status updates on our [Track Orders](#) page.

Your order will be delivered in 1 days.

### Delivery Address

Administrator  
0815 Test Street, Test, Test, 4711  
Test  
Phone Number 1234567890

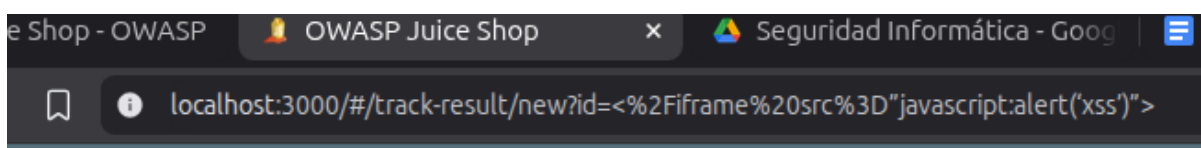
### Order Summary



| Product                | Price | Quantity | Total Price   |
|------------------------|-------|----------|---------------|
| Apple Juice (1000ml)   | 1.99€ | 3        | 5.97€         |
| Orange Juice (1000ml)  | 2.99€ | 3        | 8.97€         |
| Eggfruit Juice (500ml) | 8.99€ | 1        | 8.99€         |
| Items                  |       |          | 23.93€        |
| Delivery               |       |          | 0.99€         |
| Promotion              |       |          | 0.00€         |
| <b>Total Price</b>     |       |          | <b>24.92€</b> |

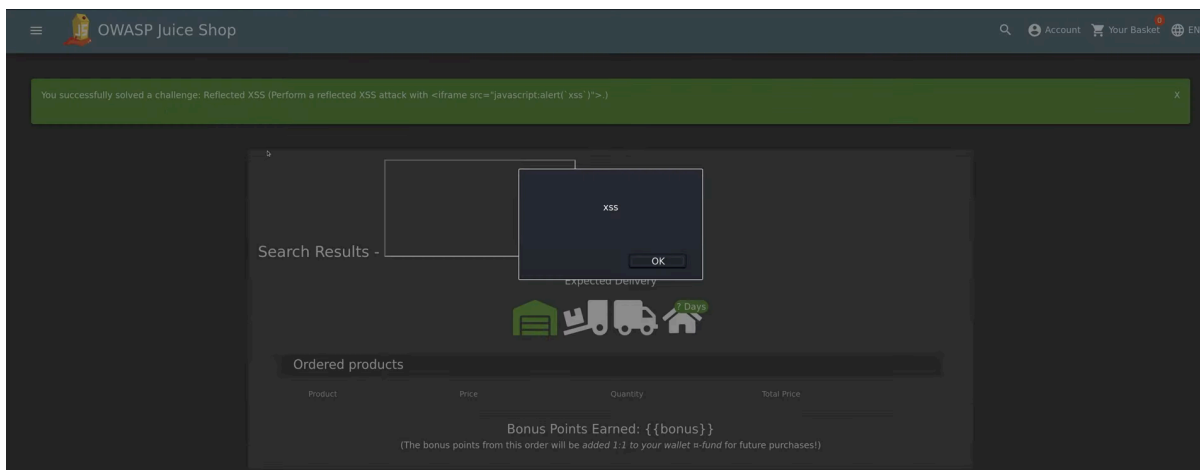
You have gained 1 Bonus Points from this order!

Una vez que lo hayamos pagado podremos hacer el seguimiento del pedido dándole a la opción Track Orders marcada de color verde



En la barra del buscador nos saldrá una ruta ...../new?id=(número del id).  
Nosotros tendremos que cambiar el numero del id por el siguiente script,  
<iframe src="javascript:alert('xss')">

Le daremos a buscar y recargamos la página web



Una vez que lo hayamos recargado nos saldrá esta alerta en la que pone XSS y como vemos detrás hemos desbloqueado el logro por haber encontrado esta vulnerabilidad

## Mitigación y Evaluación Según Criticidad

Lo primero para solucionar este ataque es que cuando la aplicación convierta los caracteres especiales en entidades seguras para que cuando el usuario introduzca caracteres como <> o " " el navegador lo muestre como texto y no lo ejecute

Otra medida importante es usar cookies seguras con las etiquetas HttpOnly para que JavaScript no pueda leer la cookie, Secure para que

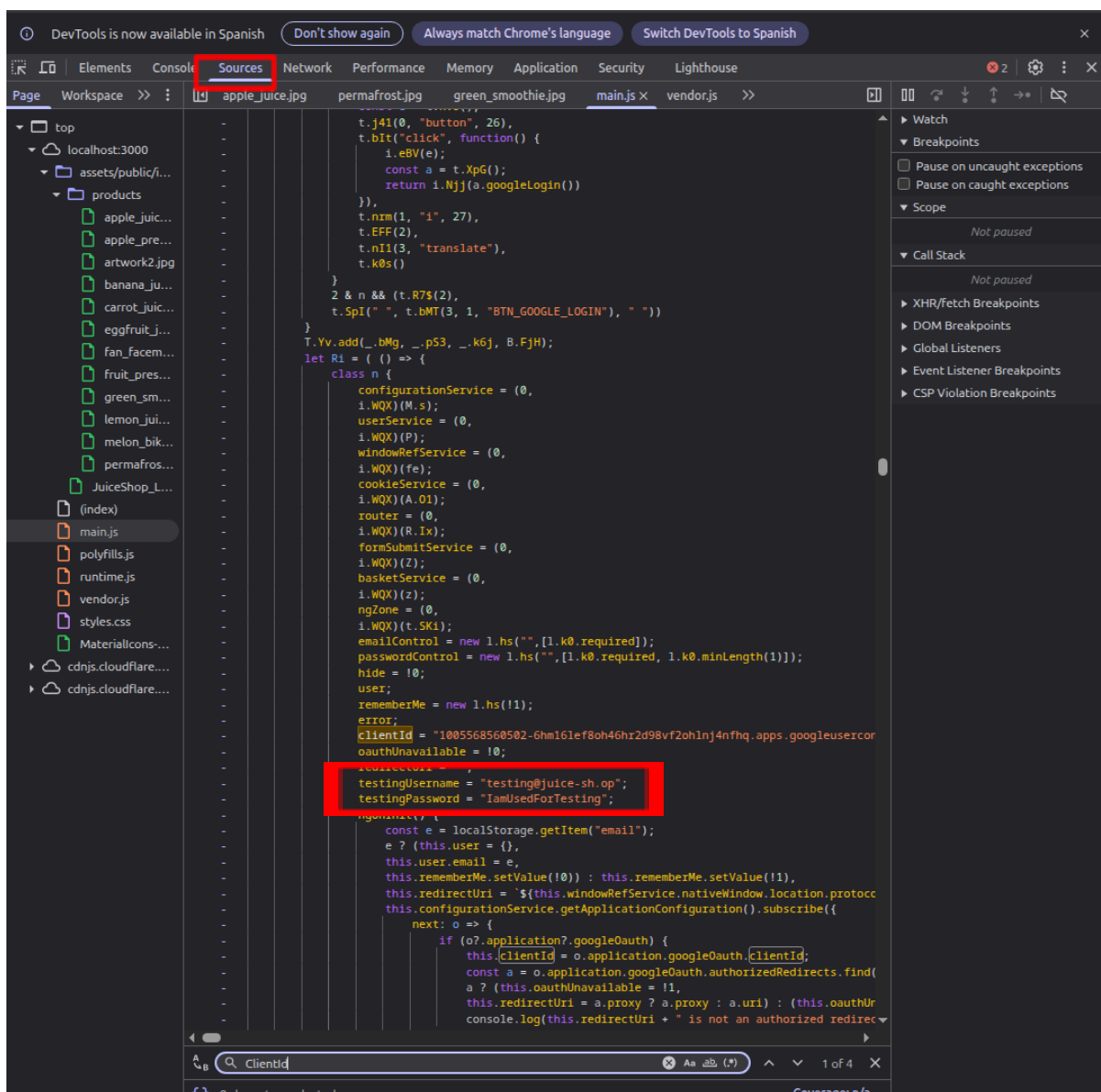


solo se envíe por HTTPS y SameSite para evitar que se envíen en peticiones de terceros

Este ataque se valora con un Nivel alto o Alta severidad porque permite ejecutar código en el navegador comprometiendo la confidencialidad y la integridad del usuario. Se pueden robar las cookies de inicio de sesión y suplantar la identidad de un usuario, se pueden cambiar datos, realizar compras, etc

## Explotación Herramienta de Desarrollador

Para este tipo de ataque tenemos que entrar en la página web y darle a la tecla F12 o FN + F12 para poder entrar a la herramienta de desarrollador que permite ver la estructura como el HTML o el CSS, acceder a la consola donde se puede ejecutar código JavaScript, ver las cookies almacenadas, etc



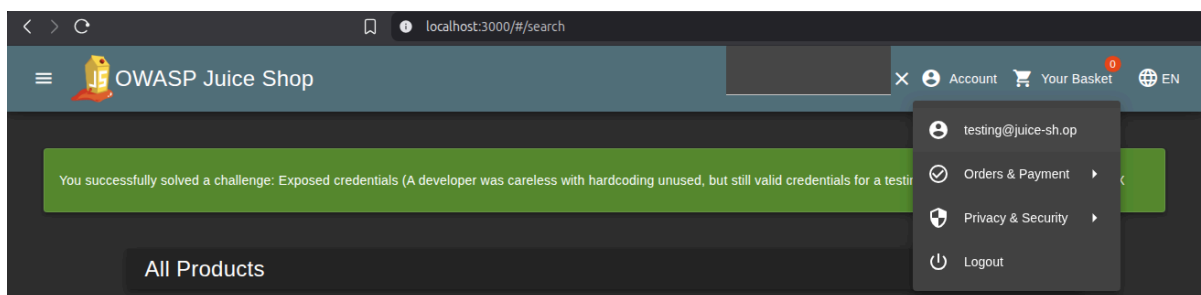
Cuando entramos en esta herramienta le daremos arriba al apartado de Sources y a la derecha se nos abrirán archivos JavaScript, librerías, archivos con código o funciones que manejan las peticiones

En este caso he visto que hay un archivo llamado main.js por lo que directamente he ido a mirarlo. Una vez dentro de ese archivo dándole a ctrl + F para poder buscar por palabras clave

He buscado palabras como cookies, email, tokenId hasta probar con la palabra ClientId con la que he podido encontrar testingUsername =



“[testing@juice-shop.op](mailto:testing@juice-shop.op)” y testingPassword = “IamUsedForTesting” en texto plano, por lo cual he podido acceder a la cuenta de este usuario



## Mitigación y Evaluación Según Criticidad

Una de las medidas principales para mitigar las contraseñas expuestas es no almacenarlas en los archivos del frontend. Otra medida es usar variables de entorno o vaults como Azure Key Vault para almacenar las contraseñas

También podemos implementar un sistema seguro de autenticación como usar tokens temporales o que los inicios de sesión están gestionadas por un servidor

Este ataque se valora con un Nivel alto o Alta severidad porque cualquier persona puede ver el email y la contraseña del usuario en texto plano y puede acceder a dicha cuenta de usuario

